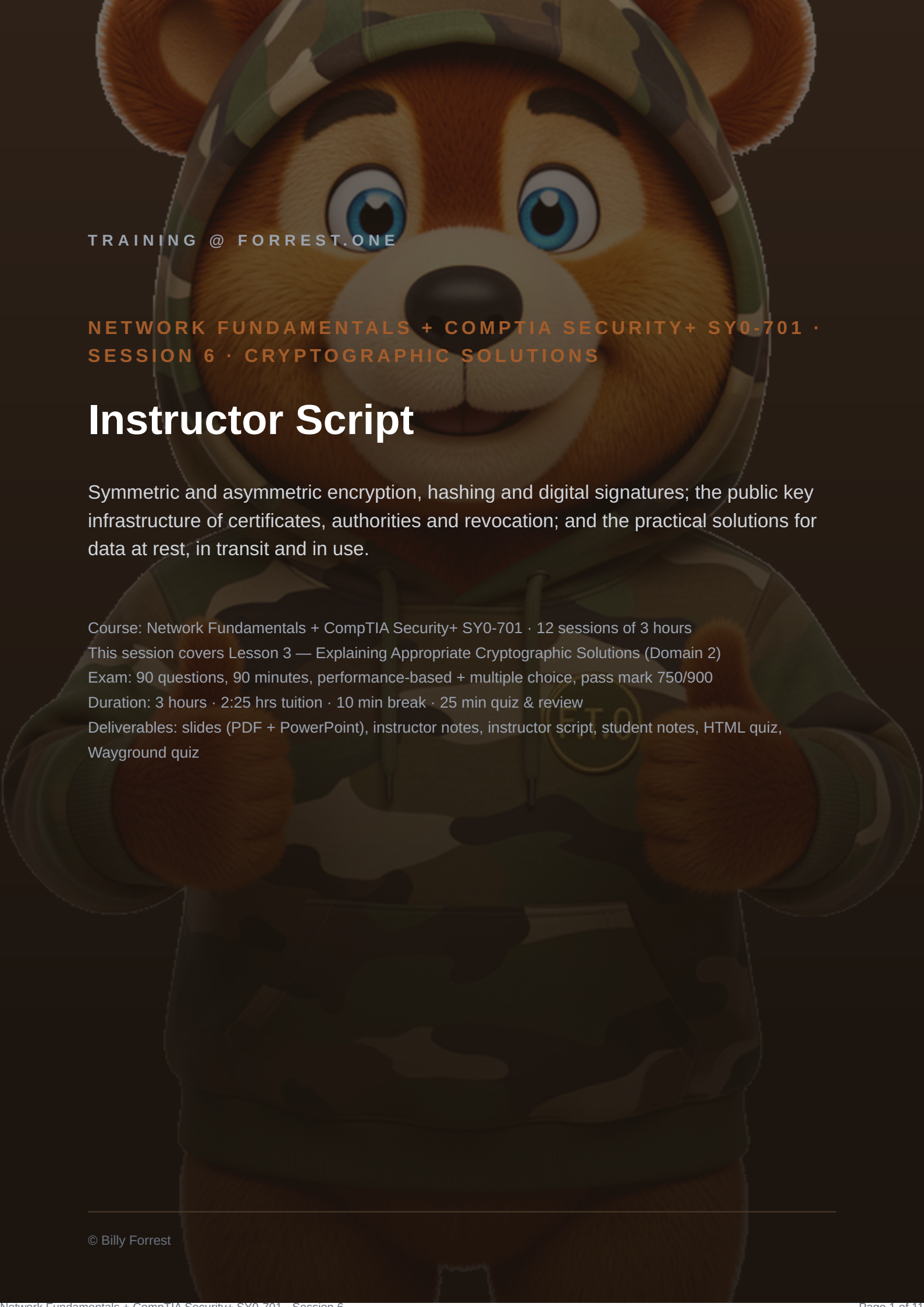




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 6 · CRYPTOGRAPHIC SOLUTIONS

Instructor Script

Symmetric and asymmetric encryption, hashing and digital signatures; the public key infrastructure of certificates, authorities and revocation; and the practical solutions for data at rest, in transit and in use.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

This session covers Lesson 3 — Explaining Appropriate Cryptographic Solutions (Domain 2)

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Instructor Script — Cryptography & Public Key Infrastructure

A word-for-word delivery script for Session 6. Stage directions appear in square brackets. Each slide runs roughly 45 to 90 seconds of speech; activities and discussions expand the timings in the instructor notes.

Slide 1 · Title

Good day, and welcome to Session 6: Cryptography and Public Key Infrastructure. This session is about cryptography, and about identity and access. We begin with the words security people use, then build the tools, which are encryption, hashing and signatures. Then we follow those tools into the certificate world, and finally into the machinery of identity. Every piece here has a job, and every piece is examinable.

Slide 2 · The CIA triad

Security rests on three principles: confidentiality, integrity and availability. Together we call them the CIA triad. Confidentiality means that only authorised people can read the data, and encryption, access controls and authentication all serve it. Integrity means the data is accurate and has not been altered, and checksums, hashes and digital signatures serve it. Availability means authorised users reach data when they need it. A stolen laptop threatens confidentiality, a tampered invoice threatens integrity, and a failed server threatens availability. Ask which of the three any control serves.

Slide 3 · Saying what you mean

Four words you must use precisely. A vulnerability is a weakness, in software, in hardware or in a process. A threat is anything that could exploit that weakness, whether an attacker or a flood. An exploit is the method or tool used to take advantage, such as an injection attack against a web form. Risk combines likelihood with impact, so you can rank your work sensibly. A weakness that is likely to be used, and would hurt badly, is the one you fix first.

Slide 4 · Session objectives

By the end of these three hours you will be able to explain symmetric and asymmetric encryption; describe hashing and digital signatures; describe public key infrastructure, its certificates, authorities and revocation; protect data at rest, in transit and in use; and then explain identity and access management, from authentication factors to RADIUS, TACACS+ and LDAP. The quiz tests every one of those outcomes.

Slide 5 · Symmetric encryption

Encryption turns readable plaintext into unreadable ciphertext. Symmetric encryption uses one key to lock the data, and the same key to unlock it. The workhorse is the Advanced Encryption Standard, or AES, with key lengths of 128, 192 or 256 bits. It is fast, so it protects large volumes: whole disks, database files and backups. BitLocker and FileVault both rely on it. The weakness is never the algorithm, but the key, because both sides need that one secret and it must reach them safely. Treat symmetric encryption as your default for bulk data.

Slide 6 · Key length matters

The range of possible key values is the keyspace, and a longer key means a larger keyspace. Each added bit doubles the work an attacker must do, which is why a 256-bit key is exponentially stronger than a 128-bit key. Longer keys defeat brute-force search. The cost is real: longer keys use more processor time, more memory and more power. Choose the strength the data actually needs, and never shorten a key to save a millisecond.

Slide 7 · Asymmetric encryption

Asymmetric encryption solves the sharing problem with a key pair: a public key and a private key, mathematically linked. Encrypt with the recipient's public key, and only their private key can decrypt. The private key cannot be worked out from the public key, and it must stay secret. The best known algorithm is RSA, from Rivest, Shamir and Adleman, and it relies on the difficulty of factoring very large primes. Elliptic curve cryptography offers comparable strength with much smaller keys, which suits mobile and constrained devices. Asymmetric work is slower, so it protects keys and signatures rather than bulk data. That is why we call it public key cryptography.

Slide 8 · How TLS uses both

Here is how the two work together, in the protocol that protects the web. Transport Layer Security begins with a handshake, and that handshake is asymmetric. The client checks the server's certificate, and a session key is exchanged: only the server can decrypt that key, using its own private key. Then both sides switch to symmetric encryption for the rest of the conversation. Asymmetric solves trust and key exchange, and symmetric carries the data itself. Keep that division in mind, because it repeats in every secure protocol you will meet.

Slide 9 · Hashing and the avalanche effect

Hashing takes data of any size and produces a fixed-length digest. It is deterministic, so the same input always gives the same digest. It is one way, meaning you cannot work back from a digest to the original data. Change a single bit, and the whole digest changes, and we call that the avalanche effect. It should also be collision resistant, so two different inputs never share a digest. Hashing gives you integrity, and it gives you nothing at all about secrecy.

Slide 10 · Hashing algorithms today

Not every hash function is still worth using. The Secure Hash Algorithm family two is the modern standard, and SHA-256 produces a 256-bit digest. Older algorithms have fallen. SHA-1 surrendered to collision attacks, where an attacker produces two different messages with one digest. Message Digest five can be made to collide on demand, so nobody should trust it for security. You still meet it as an old file checksum. Use SHA-256 or stronger, and treat anything weaker as broken.

Slide 11 · Digital signatures

A digital signature combines a hash with asymmetric encryption. The sender hashes the message, then encrypts that hash with their own private key, and the message and the signature travel together. The recipient decrypts the signature with the sender's public key, hashes the message themselves, and compares the two digests. If they match, the message is intact and it came from the holder of that private key. That gives integrity, authentication and non-repudiation, which means the sender cannot later deny it. Note what it does not give: a signature does not hide the content. Software signing and contract signing both rely on it. The exam line is short: sign with the private key, verify with the public key.

Slide 12 · Activity: which tool for which job?

[Run the activity per the instructor notes. 8 minutes in pairs, 4 minutes debrief.] Encrypting a large database backup: symmetric, for speed. Proving a contract was not altered: hashing, for integrity. Authenticating a sender beyond doubt: a digital signature. Exchanging a session key over an untrusted network: asymmetric. Name the job before you name the tool.

Slide 13 · Certificates and certificate authorities

Now the machinery that makes a public key trustworthy. A certificate authority, or CA, verifies identity and issues certificates, signing each one with its own private key. A registration authority, or RA, performs the identity checks on the authority's behalf before anything is issued. The certificate itself binds a public key to a verified identity. When a key is compromised, the authority revokes the certificate and publishes that fact. Without this binding, a public key on its own proves nothing at all.

Slide 14 · Digital certificates

What is inside a certificate? The subject's public key, information identifying the subject, the usage, and the validity period. It also carries the identity of the issuing CA and that authority's digital signature, which is how the binding is vouched for. The standard format is X.509. Two subject name attributes matter for the exam. Common Name is the legacy way of recording the fully qualified domain name, deprecated by the standards but still met. Subject Alternative Name is the modern field, and it lists structured identifiers: multiple hosts, subdomains and wildcards.

Slide 15 · Root of trust and the chain of trust

Trust has to start somewhere, and it starts with a root. The root certificate is self-signed, so you are trusting the authority's own procedures. Below the root sit intermediate authorities, which issue the certificates we actually use. That hierarchy is the chain of trust: trust the root, and the root vouches for everything beneath it. Compromise at the bottom is handled by revoking a certificate, or an intermediate, not by rebuilding the root. Without PKI you can still have certificates, but there is no root of trust to make them meaningful.

Slide 16 · The certificate signing request

How does a certificate get issued? Generate: the subject creates a key pair. Send: the public key goes to the authority in a certificate signing request, the CSR. Note the critical rule: the subject never sends the private key, and it never leaves the subject. Verify: the authority, or an RA on its behalf, performs identity checks. Issue: the authority signs the certificate and publishes it. Because certificates expire, renewal proves identity all over again before a new one is issued.

Slide 17 · Certificate revocation

Certificates can be revoked, and there are two mechanisms for telling the world. Revocation means permanent removal, and suspension is a temporary hold. The certificate revocation list is a published checklist that browsers and clients download. The Online Certificate Status Protocol queries one certificate in real time. Why revoke? Compromised keys, changed details, and trust that has expired. Revocation is one stage in the lifecycle of issuance, renewal, revocation and expiration, and its purpose is simple: a bad key must stop being trusted quickly.

Slide 18 · Key management and cryptoprocessors

Keys need secure handling. The Trusted Platform Module, the TPM, is a cryptoprocessor on the motherboard, providing tamper-evident storage and entropy for key generation. The Hardware Security Module, the HSM, is a dedicated or removable cryptoprocessor that manages keys at scale with a reduced attack surface. Key escrow backs up keys with a trusted third party, and M-of-N control splits recovery across several agents so that no single person holds all the power. Around all of it sits the key lifecycle: generation, storage, revocation, expiration and renewal.

Slide 19 · Discussion

[Run the discussion per the instructor notes.] What does a website certificate actually prove? [Take answers.] It proves that the public key belongs to the named domain, and that a trusted authority vouched for that binding. Nothing more. It does not prove the site is safe, honest or legitimate, and it says nothing about the content. The chain of trust is what makes the binding meaningful.

Slide 20 · Break

Ten minutes. When we return, we apply all of this: cryptographic solutions, then identity and access.

Slide 21 · Data states

Welcome back. Cryptography is applied by data state. Data at rest is stored data: disks, databases, backups and files. Data in transit is moving across a network, and transport encryption protects it. Data in use is being processed in memory, and it is the hardest state to protect. The rule is simple: every state needs an appropriate control, and the exam expects you to match them. Name the state before you name the technology.

Slide 22 · Disk and file encryption

Start with data at rest. Full disk and partition encryption encrypts the whole volume, often driven by the operating system or the firmware. Volume and file encryption protect selected files or containers. Self-encrypting drives perform encryption in the drive firmware itself. The benefit is easy to state: a stolen drive yields nothing without the key. The weak point is a running machine, where the key is in memory, which is why we combine disk encryption with access controls.

Slide 23 · Database encryption

Structured data adds finer controls. Database-level encryption protects the whole database, while table, column and cell-level encryption protect individual structures. The database management system decrypts as data moves from disk into memory, which is how fine-grained access is enforced. That granularity supports compliance requirements for privacy and security. The trade-off is complexity and overhead, so protect the columns that actually carry sensitive data.

Slide 24 · Transport encryption and perfect forward secrecy

For data in transit we use transport encryption: TLS and VPN tunnels. You have already seen how TLS works: an asymmetric handshake exchanges a symmetric session key, and symmetric encryption then carries the session. Perfect forward secrecy matters because those session keys are ephemeral. Compromise one key later, and it cannot decrypt past traffic, because the key that protected that traffic no longer exists. Recorded sessions stay secret. That is why perfect forward secrecy is a modern requirement, not a luxury.

Slide 25 · Salting and key stretching

Passwords need special treatment. User-chosen passwords are low entropy, so brute force eventually finds them. Salting adds a random value to each password before hashing, which defeats pre-computed tables, because every salted hash is unique. Key stretching adds extra hashing rounds, so every guess costs the

attacker more time. Salt and stretch together: slower attacks, safer storage. And never store a password in plain, or in a hash that is neither salted nor stretched.

Slide 26 · Blockchain: a distributed ledger

Chapter three is where cryptography meets everyday work, starting with the blockchain. A blockchain is a distributed ledger, copied across many nodes, with no single master copy. Each block holds a set of transactions, a timestamp, and the hash of the previous block. That previous hash is what chains the blocks together. Change anything in an old block and its hash changes, so every later block no longer matches. To rewrite history you would have to redo every later block and control most of the network. The record is therefore tamper-evident.

Slide 27 · Blockchain: applications and limits

Beyond cryptocurrency, the useful applications are provenance and records. A supply chain can record every step, giving an immutable audit trail that all parties can check. Identity systems can hold credentials in a decentralised way, so one breach exposes far less. But blockchain is not free. Public networks scale slowly, proof of work consumes enormous energy, and implementations are complex and costly. Regulation also varies by jurisdiction and is still evolving. Use it where a shared, unchangeable record is the real problem you are solving. It is a tool with a narrow best use, not a general answer.

Slide 28 · Obfuscation

Obfuscation means making data or code hard to understand. Tokenisation replaces a sensitive value with a token, and the real value stays in a secure vault, which is how payment card numbers are protected. Data masking creates a realistic but fictitious version of the data, so testers can work without exposing real people. Code obfuscation renames variables, strips out comments and buries the logic in convoluted structures, so reverse engineering becomes expensive. None of this is encryption, because the goal is confusion rather than secrecy.

Slide 29 · Steganography

Steganography hides the existence of a message, rather than its meaning. One common technique alters the least significant bits of an image's pixels, a change the human eye simply cannot see. Audio works in the same way, by shifting frequencies that listeners cannot hear, and that is also how media is watermarked. Attackers use it to conceal malware inside innocent files, to build covert channels, and to move data out past your controls. Encryption makes data unreadable, and steganography makes it invisible, so you have to hunt for both.

Slide 30 · Documentation and change management

Documentation is the backbone of security and change management, and it is examined in scenarios. Policies state the rules, procedures give the steps, and diagrams show what the network really looks like.

Diagrams must be updated after every change, or they will mislead you during an incident. Regulators expect records too, so compliance rests on what you can prove. Documentation also carries knowledge, so a departure does not take it out of the door. And a rollback plan is documented before a change is approved, never after it goes wrong.

Slide 31 · Version control concepts

Version control is how we track changes over time. A repository holds the project files together with their whole history of changes. A commit is a snapshot, carrying a unique identifier and a message that explains what changed. A branch lets someone work on a change in isolation, without disturbing the stable version of the project. Tools such as Git serve documents just as much as code. When an auditor asks what changed after an incident, this history is your answer. A commit message is documentation in miniature.

Slide 32 · Activity: match the technique

[Run the activity per the instructor notes. 8 minutes in pairs, 4 minutes debrief.] A backup tape is stolen: disk and file encryption protects data at rest. A web session must survive key compromise: perfect forward secrecy. Storing passwords: salting and key stretching. Hiding a message inside a photo: steganography. Proving a ledger entry was never altered: the hash chain. State first, then tool.

Slide 33 · Authentication and authorisation

Chapter four is about identity, and it answers three questions. Who are you, what are you allowed to do, and how do we prove it without making you log in everywhere? Start with one distinction. Authentication asks who you are, and it is proved with a password, a token or a biometric. Authorisation asks what you may do, and it decides which records you can read, edit or delete. A user can be authenticated and still be denied, and that is entirely normal. The principle of least privilege says grant the minimum needed to do the job, and nothing beyond it. It limits the damage from mistakes as much as the damage from malice.

Slide 34 · Roles and the identity lifecycle

Granting permissions user by user does not scale. Role-based access control assigns permissions to roles, and then assigns people to roles, so access follows the job rather than the individual. In a hospital, doctors, nurses and administrators each receive exactly what their work requires. Identities also follow a lifecycle: provisioning when someone joins, modification when their role changes, and deprovisioning when they leave. That last step is the one organisations get wrong. An account left active after a departure is an open door, so keep that lifecycle under review.

Slide 35 · The three factors

Authentication factors come in three families. Something you know, such as a password or a personal identification number, which we call a pin. Something you have, such as a hardware token or a smart card. Something you are, which is biometrics: a fingerprint, a face or an iris. Multi-factor authentication requires two

or more different families, so a password plus a fingerprint is genuinely stronger. A password with a pin is still single factor, because both of them are something you know.

Slide 36 · Stronger authentication

Multi-factor authentication is your best defence against a stolen password. A time-based one-time password combines a shared secret with the current time, and it stays valid for a short window, typically 30 to 60 seconds. Authenticator apps hold that secret and produce a fresh code on demand. Phishing can still relay a code, so a hardware key is stronger than a code sent to a phone. Passwordless designs remove the password altogether, using a biometric, a device key or a link sent to you. Fewer passwords means less reuse, and less reuse means fewer breaches.

Slide 37 · Single sign-on and SAML

Single sign-on lets one login open many applications. Users stop juggling passwords, so password fatigue and password reuse both fall. Administrators gain a single place to enforce policy, watch access and revoke it quickly. The Security Assertion Markup Language, or SAML, is the usual standard, and it involves two roles. The identity provider authenticates the user and issues a signed assertion. The service provider trusts that assertion and grants access, so the password never reaches the application at all. That is the pattern behind every federated login you will meet.

Slide 38 · Federation and its risks

Federation extends single sign-on across organisations. Two partners agree on standards and trust each other's identity providers, so staff from one can reach resources in the other without a second account. That suits partnerships and mergers, and it widens the trust boundary. One login is also one point of failure, so a compromise there has a wide blast radius. Protect sessions, set sensible timeouts, and encrypt tokens in transit with TLS. Add MFA at the identity provider, where one control protects every application at once.

Slide 39 · RADIUS

Chapter five is about controlling access once identity is settled. The Remote Authentication Dial-In User Service, or RADIUS, centralises authentication, authorisation and accounting. It is an open standard, so every vendor supports it. The clients are the devices that need the service: switches, wireless access points and virtual private network gateways. They collect credentials and pass them to the server, which checks them against a directory and answers accept or reject. You meet it in wireless networks, where a RADIUS server authenticates users through the 802.1X standard before they join. Without it, every switch would hold its own user list.

Slide 40 · RADIUS and TACACS+

The Terminal Access Controller Access-Control System Plus, or TACACS plus, is the Cisco alternative. The first difference is transport: RADIUS uses User Datagram Protocol and TACACS plus uses Transmission

Control Protocol, which is more reliable for authentication. The second difference is structure. RADIUS combines authentication and authorisation, while TACACS plus separates authentication, authorisation and accounting. That separation allows command-level control, so an administrator might view a switch's configuration but not change it. Use RADIUS for network access, and TACACS plus for managing the devices themselves.

Slide 41 · Directory services and LDAP

Directories hold identities, and the Lightweight Directory Access Protocol, or LDAP, is how we read and search them. The data is a hierarchy, rather like a tree, with a root that branches into organisational units and groups. A user object carries attributes: a name, an email address and login details. Microsoft's Active Directory is a directory service built on LDAP, and it adds Group Policy and Kerberos authentication. Directories are built for reading and searching, so lookups are fast, and writing to them is deliberately uncommon.

Slide 42 · Authenticating against a directory

Authenticating against a directory follows a simple pattern. The application binds to the server with the user's credentials. The server searches for a matching user object, compares those credentials against the stored values, and returns success or failure. The default port is 389, and that traffic travels in the clear. Secure LDAP wraps the whole connection in TLS on port 636, and StartTLS upgrades an existing connection instead. Encrypt directory traffic, because a directory holds credentials and the shape of your organisation.

Slide 43 · Access control lists and models

Authorisation is enforced by access control, and the oldest tool is the access control list, or ACL. An access control list holds entries attached to an object, and each entry names a subject and an action. Entries are read in order and the first match wins, so order matters. With no match, the default applies, and that is normally deny. Discretionary access control lets the owner set those entries, which is flexible but lets a careless user share too much. Mandatory access control uses a central policy that users cannot change.

Slide 44 · Attributes, place and time

Two further models give finer control. Attribute-based access control decides from several attributes at once: who you are, what the resource is, and the conditions around the request. A policy might allow a document only for the finance department, only on a managed device, and only during working time. Geofencing adds place to the decision, so sensitive data opens only inside an approved area. Time-based restrictions limit when a resource is available at all. Together these lower the value of a stolen credential. Ask which model a scenario describes.

Slide 45 · Key takeaways

Seven takeaways. One: symmetric for bulk, asymmetric for keys, because one key is fast but hard to share, and pairs solve distribution. Two: hash for integrity and sign for identity, and remember that signatures add non-repudiation. Three: certificates bind keys to identities, through X.509, CA chains, the root of trust, CRL and OCSP. Four: protect every data state, at rest with disk, file and database encryption, and in transit with TLS and perfect forward secrecy. Five: obfuscate, hide and record, using tokenisation, masking, steganography, blockchain, documentation and version control. Six: identity and access are separate, because authentication proves who you are and authorisation decides what you may do. Seven: centralise with RADIUS, TACACS plus and LDAP, and pick the right access control model.

Slide 46 · Quiz

[Direct candidates to Quiz_Session_06.html. 15 minutes.] Open the session quiz. Twenty questions, immediate feedback, and every question is tagged with the exam objective it tests, so you will see the tag above each question. Read every explanation, because the distractors teach as much as the answer. Aim for seventy percent or better before you move on.

Slide 47 · Exam alignment

Quick alignment with the paper. Objective 3.1: cryptographic algorithms, meaning symmetric, asymmetric, hashing, key length and signatures. Objective 3.2: PKI, meaning CAs, X.509, root of trust, CSR, revocation and key management. Objective 3.3: cryptographic solutions, meaning data states, disk, file, database and transport encryption, perfect forward secrecy and salting. Objective 3.4: identity and access, meaning authentication versus authorisation, factors, MFA, SSO, SAML and federation. Objective 3.5: access control, meaning RADIUS, TACACS plus, LDAP and the access control models. Scenario questions throughout: which tool fits which job.

Slide 48 · Revision checklist

Before next session: retake the quiz until you score seventy percent without guessing. Practise the jobs: for five data types, name the right cryptographic tool. Inspect a certificate in your browser, and look at its subject alternative names and its chain of trust. Learn the protocol split, RADIUS against TACACS plus, and LDAP on 389 against LDAPS on 636. Then read ahead to Session 7, where attackers will test every control you have learned.

Slide 49 · Next session preview

Next time, the threat landscape. We will cover threat actors, their attributes and their motivations; the attack surface, and the vectors that reach it; and malware, credential attacks and the mitigations that reduce risk. Take one habit from today: name the job before you name the tool. Thank you for your attention, and I will see you in Session 7.